

Capacitación y Concientización

Objetivo

Establecer una cultura de seguridad sólida en los 120 empleados de NovaTech para proteger los activos críticos, como el código fuente y los datos personales e infraestructura tecnológica.

Estrategia de Concientización Continua

Busca cambiar el comportamiento diario del personal mediante mensajes directos y recordatorios constantes sobre los riesgos invisibles.

- **Campaña Cero Sesiones Abiertas:** Implementación de señalética digital en protectores de pantalla y áreas comunes que recuerde la obligación de cerrar sesiones en equipos compartidos o visitas a clientes, con el objetivo de erradicar el acceso desde IPs desconocidas derivado de sesiones olvidadas en equipos compartidos.
- **Boletines de Seguridad Mensuales:** Difusión de casos internos de forma anónima (ej. Filtración por error en correos de soporte) para sensibilizar sobre las consecuencias reales de la falta de atención
- **Simulacros de Phishing Dirigidos:** Pruebas trimestrales de ingeniería sociales diseñadas para identificar grupos de riesgo dentro de los departamentos de Atención a Clientes y Administración, sectores que manejan alta carga de datos externos.

Plan Estructurado de capacitación

Enfocado en transmitir los conocimientos necesarios sobre políticas y normativas.

1. **Nivel Básico: Cultura de Seguridad (Todo el Personal)**
 - a. **Gestión de Credenciales:** Uso obligatorio de gestores de contraseñas y autenticación de dos factores (2FA) para mitigar el riesgo de robo de credenciales de acceso.
 - b. **Uso Aceptable de Activos:** Taller sobre las responsabilidades legales al manejar infraestructura tecnológica y dispositivos móviles de la empresa.
 - c. **Reporte de Incidentes:** Capacitación sobre el canal oficial de comunicación para reportar accesos extraños o pérdida de datos de forma inmediata.
2. **Nivel Técnico: Seguridad en el ciclo de vida (Desarrollo de Software)**
 - a. **Protección de Repositorios Git:** Entrenamiento avanzado en el control de acceso a repositorios, monitoreo de descargas y prohibición de compartir equipos para tareas de desarrollo.
 - b. **Configuración Segura de los Servidores:** Protocolos para actualizaciones de bases de datos y servidores en la nube con el fin de evitar caídas del servicio por errores técnicos.
 - c. **Criptografía y Estándares:** Introducción a métodos de protección de datos personales y financieros dentro del código fuente.

3. Nivel Administrativo: Cumplimiento y Datos (Administración y ventas)

- a. **Tratamiento de Datos Personales:** Capacitación específica sobre las obligaciones legales de la Ley Federal de Protección de Datos (LFPDPPP) para evitar filtraciones de contratos o datos de contacto.
- b. **Manejo de Información Financiera:** Procedimientos para la transferencia segura de facturas y documentos contractuales con clientes y empleados

Matriz de Ejecución y Ruta Crítica

Fase	Tipo	Activador	Meta de Cumplimiento
Inducción	Capacitación	Al contratar un nuevo personal	Firma de compromiso de confidencialidad
Refuerzo	Concientización	Mensual/ tras un incidente	100% de lectura de boletines de seguridad
Especialización	Entrenamiento	Semestral	Acreditación técnica del área de desarrollo
Validación	Evaluación	Trimestral	Reducción de incidentes por error humano

Registros y Métricas de Capacitación

Para asegurar la mejora continua y cumplir con los requisitos de auditoría interna, se establecen los siguientes controles de medición:

1. Indicadores Clave de Desempeño

- a. **Índice de Efectividad de la Capacitación:** Se mide mediante evaluaciones post-curso. La meta es que el 100% del personal obtenga una calificación superior a 80/100.
- b. **Tasa de Clic en Phishing (Simulacros):** Mide el porcentaje de empleados que caen en las pruebas de ingeniería social. El objetivo es reducir esta tasa a menos del 5% anual.
- c. **Cobertura de Inducción:** Porcentaje de nuevos empleados que completan su formación de seguridad en su primera semana (Meta: 100%).

2. Evidencia para Auditoría

- a. **Listas de Asistencia:** Firmas digitales o registros de log de la plataforma de aprendizaje.
- b. **Diplomas/Certificados:** Comprobante individual de acreditación de los módulos técnicos (especialmente para el área de Desarrollo).
- c. **Matriz de Seguimiento:** Un tablero donde el Comité de Seguridad pueda ver en tiempo real quién ha cumplido con su formación y quién tiene sesiones pendientes.
- d. **Reporte de Hallazgos:** Documento que detalle las áreas donde el personal falló más (ej. confusión en la Ley de Datos Personales) para reforzar esos temas en el siguiente ciclo.